

1. WAF (Web Application Firewall)

¿Qué es?

Un **firewall de aplicaciones web** que **filtra y monitorea el tráfico HTTP** hacia y desde una aplicación web. Su propósito es **detectar y bloquear ataques comunes** como:

- SQL Injection
- Cross-Site Scripting (XSS)
- Cross-Site Request Forgery (CSRF)
- Directory Traversal
- Ataques de fuerza bruta

¿Cómo funciona?

Opera como un **proxy inverso**, es decir, **se ubica entre el cliente (navegador) y el servidor backend**, inspeccionando todo el tráfico y aplicando reglas para permitir o bloquear solicitudes.

Ejemplos populares:

- AWS WAF
- Cloudflare WAF
- ModSecurity (open-source)
- Azure Web Application Firewall

2. CSP (Content Security Policy)

¿Qué es?

Una **cabecera de seguridad HTTP** que ayuda a **prevenir ataques XSS y otros ataques relacionados con la inyección de contenido**. Define **qué fuentes de contenido** son permitidas por el navegador (scripts, estilos, imágenes, etc.).

¿Cómo funciona?

El servidor devuelve una cabecera como esta:

1. Content-Security-Policy: default-src 'self'; script-src 'self' https://apis.google.com

Esto indica al navegador que:

- Solo se puede cargar contenido desde el mismo dominio ('self').
- Los scripts solo se permiten desde el mismo dominio y <https://apis.google.com>.

Beneficios:

- Previene ejecución de scripts maliciosos.
- Mitiga ataques XSS y data injection.

3. SAST (Static Application Security Testing)

¿Qué es?

Es una técnica de **análisis de código fuente** que permite **detectar vulnerabilidades de seguridad en el código** antes de que se ejecute (es decir, sin necesidad de desplegarlo).

¿Cómo funciona?

- Escanea el código fuente o bytecode en busca de patrones peligrosos.
- Detecta vulnerabilidades como:
 - Inyecciones de SQL
 - Uso inseguro de funciones
 - Fugas de información
 - Problemas de validación de entradas

Se integra comúnmente en el ciclo de desarrollo (CI/CD) para encontrar errores lo antes posible.

Ejemplos de herramientas SAST:

- SonarQube
- Checkmarx
- Fortify Static Code Analyzer
- Semgrep (open source)